

Vulnerability Assessment Report

OWASP JUICE SHOP WEBSITE

EXECUTIVE SUMMARY

This report presents the findings of a Passive Vulnerability Assessment conducted on the OWASP Juice Shop demo website. The objective was to evaluate the public-facing security posture and identify potential risks without disrupting service availability or modifying data.

The assessment utilized a non-intrusive methodology, employing industry-standard tools such as Nmap, OWASP ZAP, and Browser DevTools. Key findings include the exposure of administrative API configurations, permissive CORS policies, and the absence of critical security headers (HSTS and CSP). These vulnerabilities could allow unauthorized reconnaissance, session hijacking, or cross-site scripting (XSS) attacks.

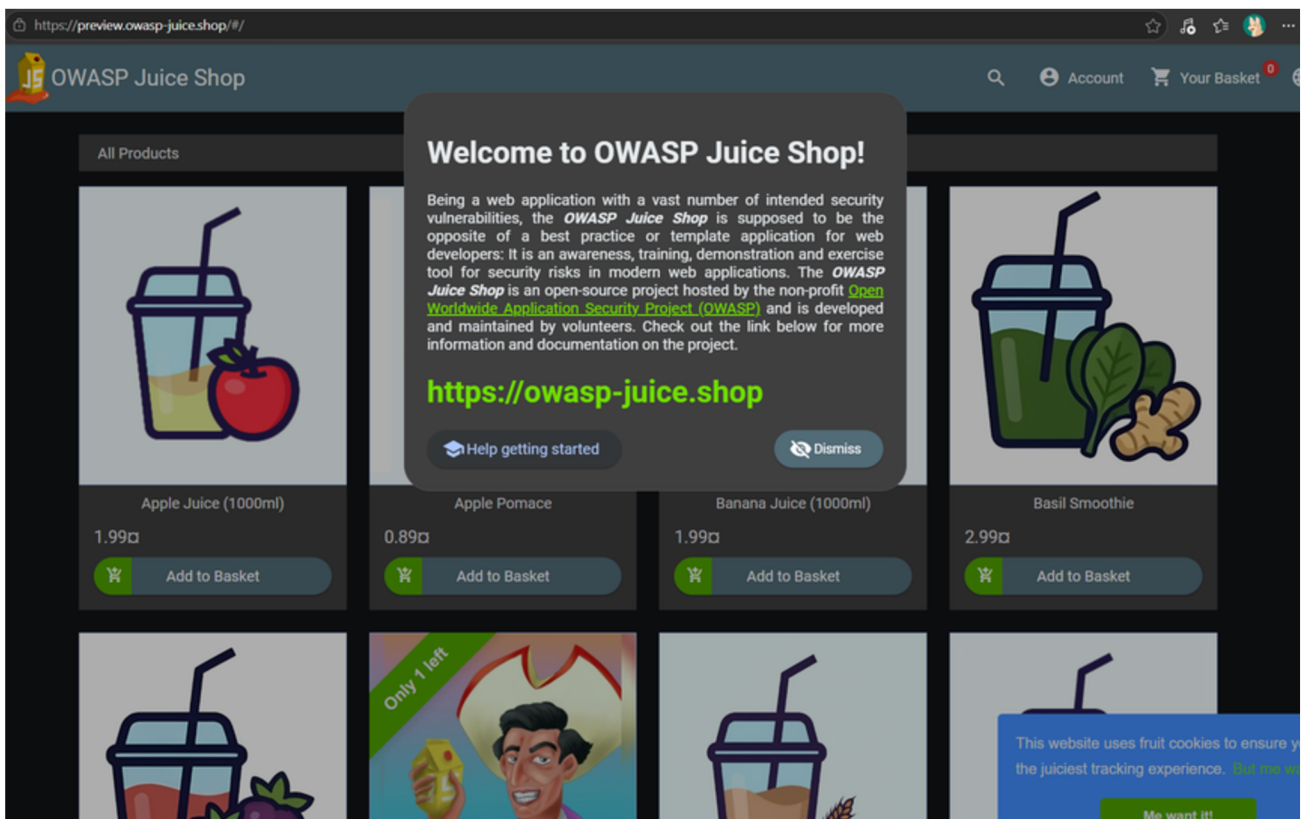
While the infrastructure benefits from basic obfuscation via cloud-based load balancers, the application layer requires hardening. Implementing the prioritized Remediation Roadmap, specifically restricting administrative endpoints and modernizing header configurations, is recommended to align the platform with global security standards and protect sensitive metadata.

This audit serves as a baseline for security posture. To achieve a comprehensive defense, a transition to Active Testing in a controlled staging environment is recommended for future phases.

Confidentiality Notice: This document is for educational purposes as part of the Future Interns program.

TARGET WEBSITE PROFILE

The **OWASP Juice Shop** is a modern, purposefully insecure web application designed for security training. It is built with Node.js, Express, and Angular that serves as a sophisticated "testbed" for simulating real-world e-commerce risks (e.g., sensitive data exposure and broken access control) within a controlled, educational scope.

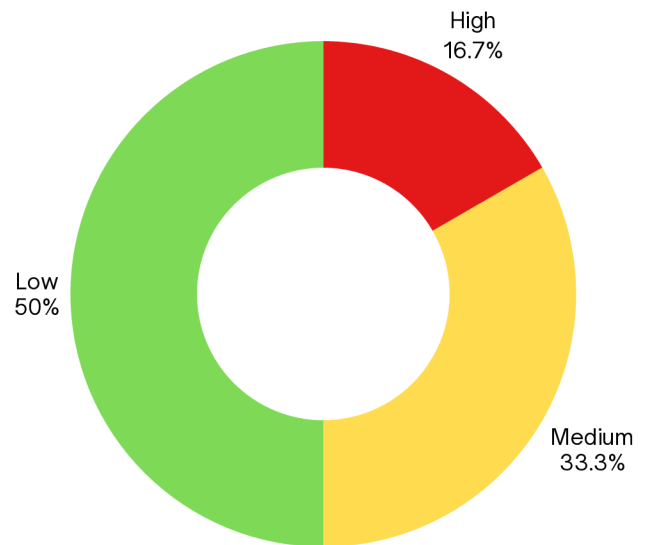


Link: <https://preview.owasp-juice.shop/#/>

RISK ASSESSMENT OVERVIEW

VISUAL SUMMARY OF RISKS DETECTED

Total Identified Vulnerabilities: 6.
Major focus required on Information Disclosure and Header Hardening.



RISK CRITERIA

The basis used to evaluate the priority of findings and the actions required to mitigate or eliminate them.

SEVERITY LEVEL	DESCRIPTION
High Risk	Critical impact on business operations. These issues are easy to exploit and could lead to data theft or service disruption. Immediate fix required.
Medium Risk	Significant impact. Requires specific conditions to exploit but compromises the defense-in-depth strategy. Plan fix within 30 days.
Low Risk	Minor impact. Primarily related to security hardening and industry best practices. Fix during scheduled maintenance.

SCOPE OF ASSESSMENT

- Strictly followed established ethical guidelines, acting as a security auditor to provide clarity on business risks without causing harm.
- Conducted a strict read-only assessment; no destructive actions, brute-force, or exploitation techniques were utilized.
- Ensured 100% uptime by focusing on publicly accessible headers, configurations, and surface-level traffic.

LIMITATIONS

- **Passive Constraints:** As a Read-Only assessment, no active payloads were sent. Vulnerabilities were identified via observation but not exploited to confirm their full impact.
- To ensure 100% uptime, aggressive scanning was avoided. Consequently, more significant results (e.g SQL Injection or XSS) might only be discovered via Active Testing in a staging environment.
- This report is a snapshot of the infrastructure as of May 2026; subsequent updates may introduce new risks.

METHODOLOGY

The following tools were utilized to assess the vulnerability of the target website in an isolated test environment:

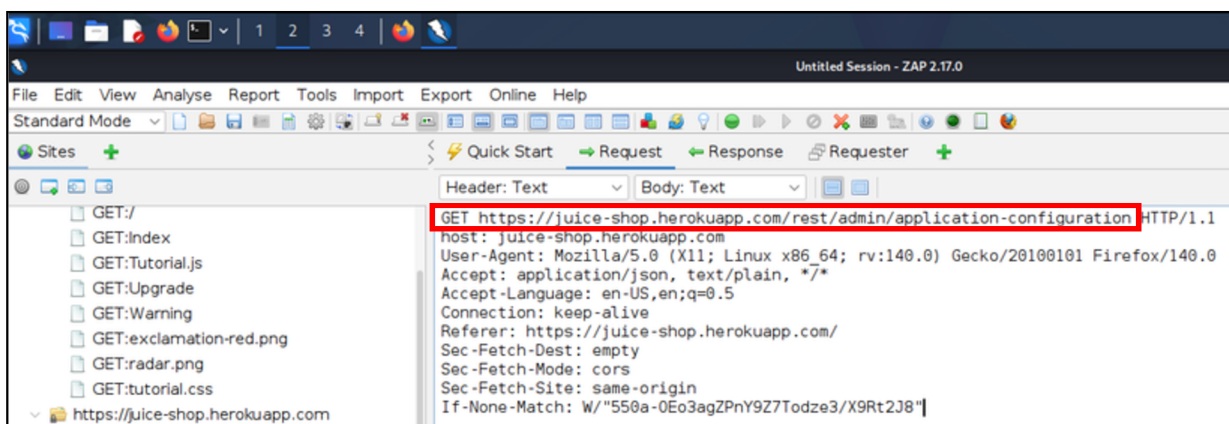
TOOL	PURPOSE
Nmap	Used for network mapping and service version identification (Fast scan, No-Ping).
Browser DevTools	Used for inspection of security headers, cookies, and console logs.
OWASP ZAP (Passive)	Used for automated identification of common web vulnerabilities without active payloads.

DETAILED FINDINGS #1

EXPOSURE OF ADMINISTRATIVE API CONFIGURATION

The application exposes an administrative REST API endpoint (/rest/admin/application-configuration) to unauthenticated public users. This endpoint is designed to provide configuration details to the client-side application.

- Risk Level: **High**
- Impact: This exposure provides an attacker with a detailed blueprint of the application's internal settings. Depending on the JSON response, this could include sensitive metadata, internal paths, or configuration toggles, facilitating further targeted attacks.



Restricting access to administrative endpoints is a fundamental pillar of Zero Trust Architecture (ZTA). The application violates the Principle of Least Privilege by exposing configuration data publicly.

DETAILED FINDINGS #2

MISSING MODERN SECURITY HEADERS

An inspection of the HTTP response headers via Nmap scripts reveals that several critical security headers are missing. While X-Frame-Options and X-Content-Type-Options are present, the site lacks a Content Security Policy (CSP) and Strict-Transport-Security (HSTS).

- Risk Level: **Medium**

Impact:

- No CSP: Increases the risk of Cross-Site Scripting (XSS) and data injection attacks.
- No HSTS: Allows for potential protocol downgrade attacks (forcing a user from https to http).

```
(kali@kali)-[~]  
$ nmap -p 80,443 --script http-title,http-headers juice-shop.herokuapp.com  
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-05 17:52 -0400  
Nmap scan report for juice-shop.herokuapp.com (46.137.15.86)  
Host is up (0.036s latency).  
Other addresses for juice-shop.herokuapp.com (not scanned): 54.73.53.134 54.220.192.176  
rDNS record for 46.137.15.86: ec2-46-137-15-86.eu-west-1.compute.amazonaws.com
```

```
| Server: Heroku  
| Vary: Accept-Encoding  
| Via: 1.1 heroku-router  
| X-Content-Type-Options: nosniff  
| X-Frame-Options: SAMEORIGIN
```

Nmap Header Extract (Port 443)

DETAILED FINDINGS #3

PERMISSIVE CORS POLICY

The header Access-Control-Allow-Origin: * was detected.

- Risk Level: **Medium**
- Impact: The use of a wildcard (*) means any website can make requests to this API. In a production environment with sensitive user data, this could lead to Cross-Origin Resource Sharing (CORS) vulnerabilities, allowing malicious sites to interact with the user's session.

```
PORT      STATE SERVICE
80/tcp    open  http
| http-headers:
|   Accept-Ranges: bytes
|   Access-Control-Allow-Origin: *
```

Nmap Header Extract (Port 80)

```
|_http-title: OWASP Juice Shop
443/tcp    open  https
|_http-title: OWASP Juice Shop
| http-headers:
|   Accept-Ranges: bytes
|   Access-Control-Allow-Origin: *
```

Nmap Header Extract (Port 443)

DETAILED FINDINGS #4

INFORMATION EXPOSURE (SERVER & RECRUITMENT METADATA)

The server explicitly identifies itself as Heroku via the Server and Via headers. Additionally, a non-standard header X-Recruiting: /#/jobs was detected.

- Risk Level: **Low**

Impact:

- Infrastructure Leak: Identifying the hosting provider (Heroku) allows attackers to narrow down their exploit research to platform-specific vulnerabilities.
- Metadata Leak: While the recruiting header is likely intentional for this demo, in a corporate environment, non-standard headers can leak internal organizational structure or project names.

```
(kali@kali)-[~]  
$ nmap -p 80,443 --script http-title,http-headers juice-shop.herokuapp.com  
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-05 17:52 -0400  
Nmap scan report for juice-shop.herokuapp.com (46.137.15.86)  
Host is up (0.036s latency).  
Other addresses for juice-shop.herokuapp.com (not scanned): 54.73.53.134 54.220.192.176  
rDNS record for 46.137.15.86: ec2-46-137-15-86.eu-west-1.compute.amazonaws.com
```

```
| Server: Heroku  
| Vary: Accept-Encoding  
| Via: 1.1 heroku-router  
| X-Content-Type-Options: nosniff  
| X-Frame-Options: SAMEORIGIN  
| X-Recruiting: /#/jobs
```

DETAILED FINDINGS #5

INFRASTRUCTURE OBFUSCATION & SERVICE FINGERPRINTING

A network-level scan was performed to identify open entry points. The results showed that **standard web ports (80 and 443)** are open, but the service version is listed as **tcpwrapped**.

- Risk Level: **Low**
- Impact: The use of tcpwrapped indicates that the application is shielded by a Load Balancer or Reverse Proxy (identified via rDNS as Amazon AWS/Heroku). This prevents an auditor or attacker from easily identifying the specific version of the web server, which is a positive defensive configuration.

```
(kali㉿kali)-[~]
└─$ nmap -sV -F -Pn juice-shop.herokuapp.com
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-05 13:36 -0400
Nmap scan report for juice-shop.herokuapp.com (46.137.15.86)
Host is up (0.15s latency).
Other addresses for juice-shop.herokuapp.com (not scanned): 54.220.192.176 54.73.53.134
rDNS record for 46.137.15.86: ec2-46-137-15-86.eu-west-1.compute.amazonaws.com
File System
Not shown: 98 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
80/tcp    open  tcpwrapped
443/tcp   open  tcpwrapped

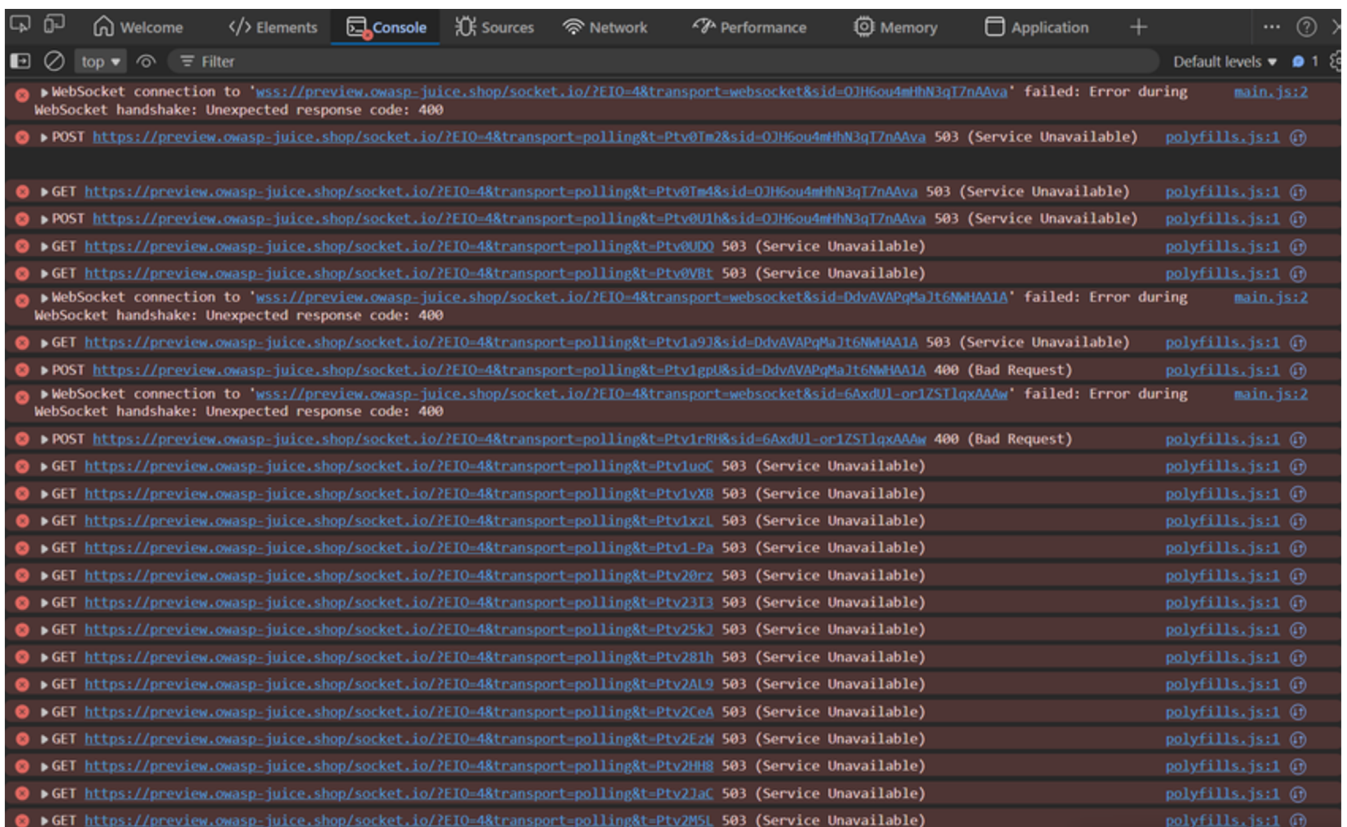
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 17.96 seconds
```

DETAILED FINDINGS #6

INFORMATION LEAKAGE VIA CONSOLE LOGS

The browser console reveals internal service errors (**503 Service Unavailable**) and file paths (`main.js`, `polyfills.js`).

- Risk Level: **Low**
- Impact: Verbose error messages provide technical details about the backend architecture (Socket.io) that could assist an attacker in reconnaissance.



REMEDIATION ROADMAP

ID	FINDING	RISK LEVEL	PRIORITY	RECOMMENDED REMEDIATE STEPS
1	Exposed Admin API	High	Critical	Implement server-side Authorization checks for the /rest/admin/ path. Ensure only authenticated admins can access configuration data.
2	Missing CSP & HSTS	Medium	High	Update web server configuration to include Content-Security-Policy and Strict-Transport-Security headers to prevent XSS and downgrade attacks.
3	Permissive CORS	Medium	High	Replace the wildcard (*) in the Access-Control-Allow-Origin header with a specific list of trusted domains.
4	Verbose Console Logs	Low	Medium	Disable production-level logging. Ensure that internal file paths and specific 503 error details are not visible to the client browser.
5	Metadata Exposure	Low	Medium	Sanitize HTTP headers to remove the Server version and non-essential metadata like X-Recruiting.
6	Service Fingerprinting	Low	Low	No action required. Maintain current use of Load Balancers/Proxies to continue obfuscating backend infrastructure.

Implementation Strategy for the Business Owner

To ensure these fixes are applied successfully without disrupting user experience, the following three-step approach is recommended:

- 1. Immediate Patching (Week 1):** Focus on the High and Medium risk items. Restricting the Admin API and enforcing a secure CORS policy will close the most significant logic gaps.
- 2. Configuration Hardening (Week 2):** Implement the missing security headers (CSP/HSTS). It is recommended to test CSP in "Report-Only" mode first to ensure it doesn't block legitimate site features.
- 3. Clean-Up & Maintenance (Monthly):** Conduct regular reviews of console logs and server headers. As the business grows in the global market, ensure these configurations align with local regulatory requirements for data protection.

CONCLUSION

The vulnerability assessment of the OWASP Juice Shop platform reveals a security posture that, while benefiting from modern infrastructure protections (such as Heroku's load balancing), still faces several application-layer risks.

The most critical area for immediate concern is the Insecure Exposure of Administrative API configurations, which bypasses the Principle of Least Privilege and provides a blueprint for targeted attacks. Furthermore, the absence of modern security headers indicates a need for enhanced Security by Design practices.

Summary of Security Posture

- **Infrastructure:** Robust. The use of reverse proxies successfully obfuscates the backend environment.
- **Application Logic:** Moderate Risk. API endpoints and session handling require stricter authorization controls.
- **Best Practices:** Requires Improvement. Standard web security headers and CORS policies must be modernized to meet international data protection standards.